RAPPORTO DI AUDIT INTEGRATO

Privacy Compliance & Artificial Intelligence Governance

Golinelli AI Playground

Piattaforma Didattica di Intelligenza Artificiale Generativa

Committente:	Fondazione Golinelli
Framework Normativo:	GDPR (Reg. UE 2016/679) AI Act (Reg. UE 2024/1689)
Data Audit:	15 Aprile 2026
Classificazione:	Documento Riservato / Uso Istituzionale

Indice

1 Introduzione e metodologia dell'Audit **2**
1.1 Metodologia di valutazione 2

2 Governance dei ruoli e responsabilità (GDPR) **2**

3 Privacy by Design: il modello "Zero Registration" **2**

4 Analisi tecnica e Data Flow Mapping **3**
4.1 Architettura del flusso dati 3
4.2 Protocolli di sicurezza attivi 3

5 Integrazione Multi-Model AI **3**

6 Classificazione AI Act (Reg. UE 2024/1689) **3**
6.1 Categorizzazione del rischio 4

7 DPIA screening e gestione dei rischi **4**
7.1 Analisi dei rischi specifici 4
7.2 Misure di mitigazione implementate 4

8 Conclusioni e rating di compliance **4**

1 Introduzione e metodologia dell'Audit

Il documento costituisce la sintesi formale delle attività di audit condotte sulla piattaforma **Golinelli AI Playground**. L'obiettivo primario è attestare il livello di aderenza tecnologica e procedurale ai vigenti regolamenti europei in materia di dati personali e sistemi di intelligenza artificiale.

1.1 Metodologia di valutazione

L'audit è stato eseguito secondo un approccio "multilivello":

- **Legal Gap Analysis:** verifica della corrispondenza tra le procedure di login/accesso e i requisiti di minimizzazione del GDPR;
- **AI Risk Screening:** classificazione dei sistemi AI integrati secondo i criteri di rischio dell'European AI Act;
- **Technical Inspection:** analisi dei flussi di dati verso i provider cloud (OpenAI, Anthropic, DeepSeek) e dei protocolli di cifratura attivi;
- **Impact Assessment:** conduzione di una DPIA screening focalizzata sulla protezione dei minori in contesti EdTech. Il dcumento costituisce una valutazione preliminare dei rischi ai sensi dell'art. 35 GDPR, finalizzata a identificare i principali impatti potenziali e le relative misure di mitigazione.

2 Governance dei ruoli e responsabilità (ex GDPR)

Una corretta applicazione del GDPR (artt. 24, 26, 28) richiede una chiara definizione dei ruoli tra la Fondazione Golinelli e gli Istituti Scolastici utilizzatori.

(GDPR/AI Act)

Principali ruoli definiti:

- **Titolare del Trattamento (Data Controller):** l'Istituto Scolastico, in quanto decide di adottare lo strumento per finalità didattiche;
- **Responsabile del Trattamento (Data Processor):** Fondazione Golinelli, che fornisce la piattaforma ed eroga i servizi su istruzioni (termini d'uso) della scuola;
- **Sub-Responsabili:** OpenAI, Anthropic e DeepSeek per l'elaborazione dei modelli LLM.

L'adozione della piattaforma si perfeziona giuridicamente con la nomina della Fondazione a Responsabile del Trattamento da parte della Scuola, garantendo così una corretta catena di responsabilità. Per specifiche attività di trattamento (es. gestione tecnica della piattaforma, dati dei docenti), la Fondazione Golinelli opera quale Titolare autonomo ai sensi dell'art. 4, par. 7 GDPR.

3 Privacy by Design: il modello "Zero Registration"

Il cuore dell'eccellenza normativa di Golinelli AI Playground risiede nella gestione degli accessi degli studenti, progettata per eliminare alla radice i rischi di identificazione diretta.

- **Accesso studenti:** non è prevista la raccolta di indirizzi e-Mail, nomi o dati anagrafici. L'ingresso avviene tramite un **Codice Sessione** temporaneo e un **Nickname** autogenerato o scelto dall'utente.
- **Risultanza legale:** questo approccio costituisce una misura di **pseudonimizzazione**

forte. In caso di data breach, i dati relativi alle interazioni AI non sono riconducibili a persone fisiche identificate senza il possesso di registri esterni tenuti solo dai docenti.

Presidio di sicurezza / Nota tecnica

La Fondazione non entra mai in possesso del registro "Nickname = Studente", che rimane sotto il controllo esclusivo dell'Istituto Scolastico. Questo realizza i requisiti previsti dall'Art. 5.1(c) del GDPR.

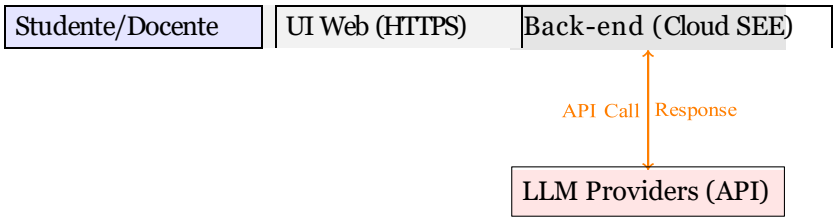
4 Analisi tecnica e Data Flow Mapping

Il flusso dei dati è progettato per garantire la sicurezza del transito e l'isolamento dei contesti didattici. I flussi di dati verso fornitori situati al di fuori dello Spazio Economico Europeo sono stati oggetto di specifica valutazione, al fine di verificare il livello di protezione garantito nei Paesi di destinazione e l'efficacia delle misure supplementari adottate.

I dati trasmessi ai provider AI sono limitati al contenuto del prompt e ai metadati tecnici strettamente necessari per la generazione della risposta, nel rispetto del principio di minimizzazione (art. 5 GDPR).

4.1 Architettura del flusso dati

Le interazioni avvengono secondo il seguente schema logico:



4.2 Protocolli di sicurezza attivi

- **Cifratura:** ogni comunicazione è protetta da TLS 1.3. I dati archiviati (sessioni) sono protetti da cifratura AES-256 a riposo.
- **Isolamento (Multi-tenancy):** ogni sessione di classe opera in un'area di memoria logica isolata; nessuna informazione viene condivisa tra diversi istituti o classi.
- Sono inoltre previste attività periodiche di verifica e aggiornamento delle misure di sicurezza, inclusi test di vulnerabilità e monitoraggio continuo delle minacce.

5 Integrazione multi-model AI

La piattaforma è agnostica rispetto ai modelli, permettendo l'uso di:

- **OpenAI (GPT-4o/o1):** utilizzato tramite Azure OpenAI o API Enterprise con clausole di non-utilizzazione dei dati per il training;
- **Anthropic (Claude):** modelli vocati alla sicurezza e all'allineamento etico;
- **DeepSeek:** modelli ad alta efficienza per compiti specifici.

Presidio di sicurezza / Nota tecnica

Sulla base degli accordi contrattuali di tipo enterprise attualmente in essere con i fornitori, i dati trasmessi non sono utilizzati per finalità proprie né per l'addestramento di modelli.

6 Classificazione AI Act (Reg. UE 2024/1689)

In conformità con il regolamento europeo, la piattaforma è stata sottoposta a screening di rischio.

6.1 Categorizzazione del rischio

- **Rischio limitato (Art. 50):** i chatbot educativi (Tutor, Quiz Master) rientrano in questa categoria. L'obbligo principale è la trasparenza (l'utente deve sapere che sta parlando con un'IA), requisito pienamente soddisfatto dalle interfacce grafiche della piattaforma.
- **Alto rischio (Esclusione):** la piattaforma non effettua valutazioni automatiche con effetti legali o decisivi sul percorso accademico dello studente. Ogni valutazione è di tipo "formativo" e mediata dal docente (**Human-in-the-loop**).

(GDPR/AI Act)

Art. 4 AI Act (AI Literacy): la piattaforma stessa è un presidio di alfabetizzazione AI, educando studenti e docenti a un uso consapevole e critico dei sistemi di intelligenza artificiale.

7 DPIA screening e gestione dei rischi

Il trattamento di dati in ambito scolastico tramite IA richiede una valutazione di impatto sulla protezione dei dati (ex art. 35 GDPR).

7.1 Analisi dei rischi specifici

Area di attenzione / Rischio

1. **Prompt Leakage:** inserimento accidentale di dati personali (e-Mail, indirizzi) nelle chat.
2. **Webcam Stream (ML Lab):** acquisizione immagini durante attività di Computer Vision.
3. **Dataset Biased:** risultati discriminatori generati dai modelli IA.

7.2 Misure di mitigazione implementate

- **Supervisione docente:** il docente ha il controllo totale sulla sessione e può intervenire in tempo reale.
- **Privacy guardian UI:** avvisi visivi costanti che ricordano di non inserire dati personali reali.
- **Edge logic:** ove possibile, l'elaborazione di dati sensibili (es. webcam per ML Lab, ecc.) avviene in memoria volatile locale e non viene inviata permanentemente ai server.

8 Conclusioni e rating di compliance

Sulla base delle verifiche condotte, Fondazione Golinelli ha implementato un sistema di gestione della conformità che si posiziona ad un livello avanzato di conformità nel contesto delle piattaforme EdTech.

- **Voto di compliance GDPR:** eccellente (grazie al modello Nickname).
- **Voto di compliance AI Act:** elevato (piena trasparenza e sorveglianza umana).

Sulla base delle verifiche effettuate e delle misure tecniche e organizzative implementate, la piattaforma presenta un elevato livello di conformità ai requisiti del GDPR e dell'AI Act. Le valutazioni espresse si basano sullo stato attuale dell'architettura tecnica e organizzativa e potranno essere oggetto di aggiornamento in caso di modifiche sostanziali del sistema o del quadro normativo.

Fondazione Golinelli